

Informe de Evaluación de Riesgo Digital y Exposición de Superficie de Ataque II

Sector: Rastreo GPS y Telemática Vehicular (IoT/MDVR)

Fecha: 20 de Agosto de 2026

Analista: Alexander Jiménez

Nivel de Confianza General del Informe: Moderado-Alto (Basado en fuentes abiertas pasivas y correlación de datos).

1. OBJECTIVE (Objetivo)

Identificar y evaluar la exposición digital pasiva de empresas representativas del sector de rastreo GPS y telemática vehicular, con el fin de determinar riesgos potenciales de Digital Risk Protection (DRP).

El análisis se centra en descubrir:

- Subdominios no documentados o expuestos (ej. paneles de administración, APIs de clientes).
- Servicios de red innecesariamente expuestos a internet (ej. bases de datos, puertos de gestión de dispositivos IoT).
- Filtración de credenciales o correos corporativos asociados a la infraestructura.

Impacto de Negocio: En este sector, una brecha no es solo un incidente técnico; compromete la promesa de valor fundamental del servicio (seguridad y privacidad de la ubicación en tiempo real), lo que puede derivar en pérdida de confianza de clientes B2B, implicaciones regulatorias y daño reputacional severo.

2. METHODOLOGY (Metodología)

La investigación se realizó exclusivamente mediante técnicas de **OSINT Pasivo** (sin interacción directa ni escaneo activo intrusivo contra los objetivos), garantizando el cumplimiento ético y legal. El proceso siguió el Ciclo de Inteligencia adaptado:

1. Recolección de Datos (Collection):

- **Reconocimiento de Dominios:** Uso de `crt.sh` y `theHarvester` para identificar subdominios y certificados SSL históricos asociados a los dominios objetivo.
- **Análisis de Superficie de Ataque:** Consulta pasiva en `Shodan` y `VirusTotal` para identificar puertos abiertos, banners de servidores, tecnologías web expuestas y posibles vulnerabilidades conocidas.

- **Filtración de Credenciales:** Búsqueda de correos corporativos y hashes asociados en bases de datos de filtraciones públicas (ej. mediante búsquedas avanzadas de Google Dorks).

2. Procesamiento y Correlación (Processing):

- Limpieza y estructuración de los datos recolectados utilizando scripts de Python (pandas) para eliminar duplicados y correlacionar direcciones IP con dominios específicos.

3. Análisis Estructurado (Analysis):

- Aplicación de evaluación de hipótesis para determinar la probabilidad de explotación de las exposiciones encontradas, asignando un **Nivel de Confianza** (Alto, Moderado, Bajo) a cada hallazgo basado en la calidad de la fuente.

4. Diseminación (Dissemination):

- Redacción de este informe estructurado, priorizando hallazgos accionables y recomendaciones de mitigación para la postura de seguridad.

3. FINDINGS (Hallazgos)

Durante el análisis pasivo de la superficie de ataque de una empresa representativa del sector (referida en este informe como **Empresa Objetivo A**, plataforma de gestión y seguimiento de flotas GPS), se identificaron las siguientes configuraciones y exposiciones críticas en su host principal 52.148.X.X (Azure, Ámsterdam):

- **Hallazgo 1: Configuración de CORS Permisiva en Aplicación Autenticada.** El servidor responde en el puerto 443 con la cabecera `Access-Control-Allow-Origin: *`. Dado que la aplicación maneja sesiones activas (evidenciado por la cookie `SSESS...` de Drupal), esta configuración permite que cualquier dominio externo solicite datos al servidor, creando un vector potencial para ataques de exfiltración de datos o CSRF si no existen mitigaciones adicionales a nivel de aplicación.
- **Hallazgo 2: Fuga de Información de la Pila Tecnológica (Tech Stack Disclosure).** El puerto 80 expone una página por defecto de "Welcome to nginx!", revelando explícitamente el sistema operativo (Ubuntu) y la versión del servidor web (Nginx 1.24.0). El puerto 443 revela que la aplicación está construida sobre Drupal 10 y PHP 8.3.8.
- **Hallazgo 3: Alertas de Vulnerabilidades Críticas en la Pila (Requiere Verificación).** Shodan asocia la versión reportada de PHP (8.3.8) con múltiples vulnerabilidades de alta y crítica severidad (ej. CVE-2024-8932, CVE-2024-11235, relacionadas con *Use-After-Free* y ejecución remota de código). *Nota: Esto puede ser un falso positivo si el proveedor ha aplicado parches de backporting, pero la versión expuesta lo flaggea automáticamente.*
- **Hallazgo 4: Soberanía de Datos en la Nube.** La infraestructura que sirve a esta plataforma de rastreo GPS está alojada en Microsoft Azure, región Europa Occidental (Ámsterdam).

4. ASSESSMENT (Evaluación)

- **Nivel de Confianza:** Alto para los hallazgos de configuración (CORS, Tech Stack). Moderado para la explotabilidad real de las CVEs (requiere prueba de concepto o verificación de parches del vendor).
- **Análisis de Riesgo:**
 1. **Riesgo de Integridad y Confidencialidad de Datos (Alto):** La combinación de una plataforma de rastreo GPS (que maneja ubicaciones en tiempo real, datos de conductores y rutas) con una configuración CORS `*` es una bandera roja de *Digital Risk Protection*. Si un atacante logra engañar a un usuario autenticado para que visite un sitio malicioso, podría aprovechar esta configuración para robar tokens de sesión o datos de la flota.
 2. **Riesgo de Exposición de Superficie de Ataque (Moderado):** La página por defecto de Nginx en el puerto 80 indica una configuración de servidor web subóptima. Idealmente, el puerto 80 debería redirigir forzosamente (301) al 443 sin revelar banners de versión.
 3. **Riesgo Regulatorio (Moderado):** El alojamiento en la UE implica que los datos de clientes latinoamericanos o de otras regiones están sujetos a las normativas de transferencia internacional de datos (GDPR y leyes locales de protección de datos).

5. RECOMMENDATIONS (Recomendaciones)

1. **Remediación Inmediata de CORS:** Restringir la cabecera `Access-Control-Allow-Origin` para que acepte únicamente los dominios legítimos y de confianza de la organización (ej. `https://app.empresaobjetivo.com`), eliminando el comodín `*`, especialmente en endpoints que manejan sesiones o datos sensibles.
2. **Endurecimiento del Servidor Web (Hardening):** Configurar el bloque del servidor Nginx en el puerto 80 para realizar una redirección 301 silenciosa al puerto 443, eliminando la página de bienvenida por defecto y ocultando los banners de versión (`server_tokens off;`).
3. **Verificación de Parches de Seguridad:** El equipo de seguridad debe auditar internamente si la versión de PHP en producción cuenta con los parches de *backporting* para las CVEs críticas reportadas. Si no es así, se debe programar una actualización inmediata.
4. **Auditoría de Arquitectura de Sesión:** Revisar que las cookies de sesión (`SSESS...`) tengan estrictamente habilitados los flags `Secure`, `HttpOnly` y `SameSite=Lax` o `Strict` en todos los endpoints.